



监管合规与 AI 安全运营

把 AI 工具放进可治理环境

HackProve World 2026 白帽世界大会中国·澳门

主题 03 00:11:52–00:38:45

目录

1	本讲义的定位	3
2	从“能用 AI”到“会治理 AI”	3
2.1	演讲线索：AI 的有效区与失效区	3
2.2	可治理环境的六个问题	3
3	首次定义：AI 安全运营	4
3.1	AI 安全运营的四类对象	4
3.2	运营闭环	5
4	首次定义：SAIF	5
4.1	从 SAIF 到运营控制	5
5	首次定义：风险矩阵 R/A/T/C/E	6
5.1	矩阵示例：报告生成	6
6	权限：把能力关进边界	7
6.1	权限分层	7
6.2	权限与场景敏感度	7
7	日志：没有记录就没有治理	7
7.1	应记录的最小字段	7
7.2	日志的反向价值	8
8	评估：把“看起来对”变成“有证据对”	8
8.1	评估指标	8
9	合规：把规则嵌入工具链	9
9.1	合规控制点	9
9.2	合规与效率的关系	9
10	可解释报告：客户需要能修复的结论	9
10.1	一份可解释报告的六个要素	9
11	责任分配：人类仍在环内	10
11.1	RACI 责任表	10
12	从一次性测试到运营闭环	10
13	官方参考	11

14 配图接口	11
15 结语	11

1 本讲义的定位

本主题讨论的是 AI 在安全测试、报告写作、工具增强、客户服务与运营环境中的落地。演讲者 Trevor Slattery 从渗透测试公司的日常工作出发，反复强调一个朴素判断：AI 的价值来自把测试人员从低价值、重复性、格式化的工作中释放出来，同时保留人类复核、上下文判断与责任边界。若把 AI 当作无人看管的自动化机器，输出会迅速变成噪声、幻觉、错误证据和合规风险。

这份讲义把该内容压缩成一个核心问题：**如何把 AI 工具放进可治理环境**。可治理环境像实验室里的通风橱：工具仍然能工作，人员仍然能探索，但空气流向、危险物留存、操作记录和紧急关闭机制都有边界。对应到 AI 安全运营，就是权限、日志、评估、合规、可解释报告与责任分配。

阅读边界：本讲义不展开 CPU 漏洞机制，也不展开 MCP 工具传播机制。后续主题会分别处理硬件漏洞响应与工具协议风险。本主题只讨论组织如何治理 AI 工具的使用。

2 从“能用 AI”到“会治理 AI”

2.1 演讲线索：AI 的有效区与失效区

本段演讲先给出一个实务视角：AI 已经进入安全工作台，但它的收益并不均匀。演讲者提到的高价值场景包括：

- **报告写作：**把测试人员记录的快速笔记、截图、证据和初步判断，整理成客户能理解、能修复的交付物。
- **威胁建模：**在测试开始前，用 AI 生成第一版风险思路，再由测试人员补充业务上下文、设备约束和真实攻击面。
- **模糊测试与测试用例扩展：**围绕既有上下文生成更多变体，帮助测试人员更快覆盖边界情况。
- **脚本与工具增强：**快速理解工具失败原因，生成小脚本，辅助测试团队把临时发现转成可重复流程。
- **证据归纳：**把发现、影响、修复建议和复现证据组织成可解释报告。

演讲者也明确指出若干低价值或高风险场景：随机字典生成、大范围自动侦察、无人监管的自动化利用、缺少上下文的漏洞解释。这些场景的共同问题是 AI 很容易生成看似合理的内容，却没有证据链支撑。安全运营里最危险的东西，常常就是“语气像真的、证据像假的”。

2.2 可治理环境的六个问题

企业真正需要回答的重点，要从“是否允许 AI”推进到下面六个更具体的问题：

- 1. 谁可以调用 AI 工具？
- 2. AI 可以接触哪些数据、证据、截图、代码和客户信息？
- 3. AI 可以调用哪些内部工具或外部服务？
- 4. 每一次调用如何记录、复盘和审计？
- 5. 输出如何评估、批准并转成客户可见报告？
- 6. 发生错误时，责任由谁承担、如何纠正、如何防止复发？

这六个问题把 AI 从“聪明插件”变成“受治理的生产能力”。一个没有治理的 AI 工具像没有门禁的实验台：它也许能加速工作，但谁拿走了样本、谁改了记录、谁把错误结论发给客户，事后都很难追清。

3 首次定义：AI 安全运营

AI 安全运营指组织围绕 AI 模型、工具、数据、人员和流程建立的一套持续治理活动，用来识别风险、限制权限、记录证据、评估输出、满足合规要求，并把责任分配到可执行的角色上。它的对象包括人员、工具、数据和流程四类资产；它的目标是让 AI 在安全工作中成为可审计、可复盘、可纠错的能力。

可以把 AI 安全运营理解成安全团队的“机场塔台”。模型像飞机，工具像跑道和导航设备，数据像货物，测试人员像飞行员，客户报告像最终航班记录。塔台不替飞机飞行，但塔台决定起降许可、记录航迹、处理异常、协调责任。缺少塔台，单架飞机仍能起飞，整个机场却无法可靠运行。

3.1 AI 安全运营的四类对象

对象	治理重点	本主题中的例子
人员	角色、审批、复核、责任	测试人员必须复核 AI 输出；高风险环境需要人工在环。
工具	调用范围、执行边界、版本与来源	报告生成、威胁建模、模糊测试、脚本生成工具要分级管理。
数据	敏感度、最小必要、脱敏与留存	渗透测试会接触客户敏感信息、知识产权、截图和证据。
流程	输入、输出、评估、发布与回滚	AI 输出进入客户报告前，需要证据检查和人工批准。

3.2 运营闭环

AI 安全运营属于持续闭环，不能停留在一次性采购清单：

授权 → 执行 → 记录 → 评估 → 报告 → 复盘

其中“授权”决定谁能做什么，“执行”约束工具行为，“记录”留下证据，“评估”发现错误，“报告”对外解释影响与修复，“复盘”把问题沉淀成规则。闭环缺一环，AI 都会从生产力工具滑向不可控风险源。

4 首次定义：SAIF

SAIF 是 Google 提出的 Secure AI Framework，即安全 AI 框架，用于把传统软件安全经验迁移到 AI 系统治理中。根据 `official_references.md` 中收录的 Google 官方资料，SAIF 覆盖模型盗取、数据投毒、prompt injection、训练数据泄露等风险，并强调安全基础、检测响应、自动化防御、平台控制、控制适配和端到端风险评估。

在本主题中，SAIF 的价值在于给“可治理环境”提供结构化语言。它让团队把抽象的“AI 有风险”拆成更可执行的问题：资产在哪里、威胁从哪里来、控制是否存在、证据是否充足、剩余风险是否可接受。

4.1 从 SAIF 到运营控制

SAIF 视角	安全运营翻译	落地检查问题
安全基础	身份、权限、隔离、配置基线	AI 工具是否只接触任务所需数据？
检测响应	日志、告警、异常行为调查	是否能追踪一次报告结论来自哪些输入？
自动化防御	自动校验、策略拦截、风险提示	是否能自动标记缺证据、过度推断和敏感信息？
平台控制	工具入口、模型入口、数据入口	是否存在统一入口管理模型与工具调用？
控制适配	按业务、风险、模型能力调整控制	医疗、工业、金融场景是否执行更严格审批？
端到端评估	从需求到报告的全流程风险评估	输出发布前是否完成证据、影响、修复建议核验？

5 首次定义：风险矩阵 R/A/T/C/E

本讲义采用 *R/A/T/C/E* 风险矩阵来描述 AI 安全运营中的治理对象：

- **R Risk, 风险**：某个威胁作用在某类资产上造成损害的可能性与影响。可写为

$$R = P(T | A) \times Impact$$

其中 $P(T | A)$ 表示在资产 A 存在时威胁 T 发生或奏效的概率， $Impact$ 表示影响。实际运营中常用高、中、低等级替代精确数值。

- **A Asset, 资产**：模型、数据、证据、代码仓库、客户系统、用户会话、业务接口、报告草稿等需要保护的對象。
- **T Threat, 威胁**：攻击者能力、误用路径、模型幻觉、越权调用、敏感信息泄露、错误报告发布等威胁组合。
- **C Control, 控制**：权限、隔离、审计、检测、速率限制、人工审批、输出校验、脱敏等防护措施。
- **E Evidence, 证据**：日志、截图、测试输出、模型响应、审批记录、报告版本和复盘记录。

这组符号的作用类似安全运营里的“五格抽屉”。团队遇到一个 AI 使用场景时，不应只问“能不能用”，还要把资产、威胁、控制和证据分别放进抽屉里。若某个抽屉为空，风险判断就很可能失真。

5.1 矩阵示例：报告生成

维度	报告生成场景中的含义
<i>A</i>	测试笔记、截图、客户系统信息、漏洞证据、报告草稿、修复建议。
<i>T</i>	AI 编造影响、误读证据、泄露客户敏感信息、把未验证结论写入正式报告。
<i>C</i>	数据脱敏、证据字段模板、输出事实检查、人工复核、客户可见内容审批。
<i>E</i>	输入材料清单、模型输出、人工修改记录、最终报告版本、审批人和时间。
<i>R</i>	若报告面对客户或监管方，错误影响高；若只是内部草稿，影响较低但仍要保留证据。

6 权限：把能力关进边界

AI 工具的权限设计要遵循最小必要原则。它能读什么、写什么、调用什么、提交什么，都要与任务目的绑定。演讲中提到渗透测试会接触敏感产品、知识产权和可能造成严重后果的环境。把这些材料直接交给 AI 处理，必须先回答数据边界和执行边界。

6.1 权限分层

1. **只读分析层**：允许读取脱敏笔记、公开资料和测试摘要，用于初步整理、分类和问题归纳。
2. **受限生成层**：允许根据证据生成报告草稿、威胁模型草稿和测试用例草稿，但不能直接发布。
3. **工具辅助层**：允许生成脚本、解释工具输出、辅助模糊测试，执行前需要人类确认。
4. **高风险执行层**：涉及真实客户系统、生产环境、医疗设备、工业控制系统时，需要强审批、隔离环境和人工在环。

6.2 权限与场景敏感度

同样的 AI 行为，在不同业务环境里风险差异巨大。对测试靶场生成脚本，风险相对可控；对医院设备、工业控制系统或赌场系统发起自动化测试，错误动作可能造成业务中断、财产损失甚至人身风险。运营规则必须随着 *Impact* 增大而加严。

7 日志：没有记录就没有治理

AI 工具调用要留下足够证据。日志不只是排障材料，它也是合规证明、责任分配和质量改进的基础。没有日志的 AI 输出像没有底稿的审计报告：结论再漂亮，出了问题也无法解释。

7.1 应记录的最小字段

字段	说明
调用入/角色	谁发起调用，属于测试人员、报告作者、审核人还是自动化流程。
任务目的	报告整理、威胁建模、脚本生成、证据归纳、模糊测试扩展等。
输入摘要	输入材料类型、敏感等级、脱敏状态、对应测试项目。

模型与工具版本	使用了哪个模型、哪个工具、哪个模板或工作流版本。
输出摘要	AI 产出类型、关键结论、置信说明、是否进入报告。
人工处理	谁复核、修改、驳回或批准；修改了哪些关键判断。
证据关联	关联截图、测试日志、复现步骤、客户影响和修复建议。

7.2 日志的反向价值

日志还能反向校准 AI 的使用边界。若团队发现某类任务经常被人工大幅重写，说明这类任务尚不适合自动化；若某类任务输出稳定、证据关联清晰，就可以逐步提高模板化程度。日志像健身记录：它既证明做过，也暴露动作是否走样。

8 评估：把“看起来对”变成“有证据对”

演讲者多次强调 AI 输出必须验证。报告、威胁建模和证据整理的风险并不在于 AI 会出错，因为人也会出错；真正的问题是 AI 会用流畅语言降低人的警觉。治理环境要把“看起来对”拆成三个可检查层级：

- 1. **事实层**：漏洞、系统、版本、影响、截图、日志是否真实存在。
- 2. **推理层**：从证据到影响的推理是否成立，是否有过度外推。
- 3. **交付层**：报告语言是否准确、修复建议是否可执行、客户能否据此行动。

字幕里还有一个具体例子：AI 会生成看似专业却不存在的 CVE 编号或 CWE 类别。安全报告一旦把这类术语幻觉写成确定事实，客户可能按错误优先级修复，合规团队也可能被误导。因此，CVE、CWE、产品版本、影响范围这类字段要逐项回连到证据来源；无法回连时，只能写成待验证线索。

8.1 评估指标

指标	含义	运营用途
证据命中率	报告结论能否关联到真实证据	过滤无证据结论和幻觉内容。
人工修改率	人类审核对 AI 输出修改的比例	判断任务是否适合继续自动化。
敏感信息泄露率	输出中未授权暴露敏感信息的比例	校验脱敏和权限控制。

复现完整度	报告是否给出足够复现和修 复依据	保障客户能行动。
审批通过率	输出进入正式交付前的通过 比例	衡量模板、提示词和流程质量。

9 合规：把规则嵌入工具链

合规不能只停在 PDF 末尾的一段声明。对于 AI 安全运营，合规要进入工具链：输入前做敏感等级判断，处理中做权限与隔离，输出前做证据和措辞审查，发布后保留可审计记录。

9.1 合规控制点

- **数据进入前**：确认客户授权范围、敏感等级、脱敏策略和保留期限。
- **模型调用中**：限制模型可见字段，避免把完整客户资料、凭据、内部知识产权直接暴露给不必要的处理环节。
- **工具执行时**：高风险动作需审批，真实环境测试需人工在环，自动化扫描必须有速率和范围限制。
- **报告发布前**：检查证据、影响、复现、修复建议和敏感信息；未验证内容不得写成确定结论。
- **项目结束后**：归档日志、报告版本、审批记录和复盘结论，按客户协议处理留存材料。

9.2 合规与效率的关系

合规控制会增加一些摩擦，但它换来的是可持续使用 AI 的资格。若没有这些控制，短期效率提升可能被一次错误报告、一次敏感信息泄露或一次未授权测试全部抵消。安全团队要把合规当作护栏，护栏让车可以开得更快，也让失误有机会停在路内。

10 可解释报告：客户需要能修复的结论

演讲者把报告写作列为高 ROI 场景，原因很直接：测试人员常有大量零散笔记，客户真正需要的是“发生了什么、影响是什么、如何修”。AI 可以把碎片变成结构，但报告的解释责任仍属于团队。

10.1 一份可解释报告的六个要素

1. **发现**：问题是什么，出现在哪个系统、接口或流程。

2. **证据**：截图、日志、请求响应、测试输出或复现记录。
3. **影响**：攻击者能获得什么能力，会造成什么业务后果。
4. **边界**：哪些结论已验证，哪些只是合理怀疑。
5. **修复建议**：客户可以采取的具体措施，包含优先级。
6. **审核记录**：谁生成草稿、谁复核、谁批准进入交付。

AI 适合生成初稿、统一格式和补全说明。最终报告必须回到证据。没有证据支撑的华丽文字，对客户来说就是高质量噪声。

11 责任分配：人类仍在环内

本主题最硬的结论是：AI 可以增强流程，但责任不能外包给 AI。演讲者特别提到，任何输出仍然需要 human review；在高风险环境里，自动化扫描和自动化利用尤其敏感。

11.1 RACI 责任表

活动	负责 R	批准 A	咨询 C	知会 I
AI 工具接入	安全运营	安全负责人	法务/合规/IT	测试团队
敏感数据输入	项目负责人	客户授权方/安全负责人	合规	测试人员
报告草稿生成	测试人员	项目负责人	AI 工具管理员	客户经理
高风险测试执行	资深测试人员	项目负责人	客户技术联系人	安全负责人
正式报告发布	项目负责人	交付负责人	法务/合规	客户团队
事故复盘	安全运营	安全负责人	项目组/合规	管理层

RACI 中的 Responsible、Accountable、Consulted、Informed 把“谁做、谁担责、问谁、通知谁”拆开。AI 工具不应出现在 Accountable 栏。它可以辅助执行，但最终责任要落在人和组织角色上。

12 从一次性测试到运营闭环

若 AI 只用于一次报告，它像临时外包；若 AI 被纳入权限、日志、评估、合规和责任体系，它才成为安全运营能力。闭环落地可从以下顺序开始：

1. 选择一个高 ROI、低风险场景，例如报告草稿整理。

2. 明确输入材料的敏感等级和脱敏规则。
3. 固定输出模板，把证据、影响、修复建议设为必填字段。
4. 建立人工复核和审批记录。
5. 统计人工修改率、证据命中率和敏感信息问题。
6. 根据评估结果扩大或收缩 AI 的使用范围。

这套路径听起来保守，但实务上很必要。AI 进入安全工作流后，真正的成本不只来自模型调用费用，也来自错误输出、错误信任、错误自动化和错误交付。治理的意义，就是把这些隐性成本提前摊开。

13 官方参考

本节只使用 `official_references.md` 收录的官方资料。它们在本讲义中的作用是校准术语和治理框架，正文主线仍以本主题演讲材料为核心。

- Google, *Introducing Google's Secure AI Framework*. <https://blog.google/innovation-and-ai/technology/safety-security/introducing-googles-secure-ai-framework/>。用于定义 SAIF，并说明 AI 系统治理需要覆盖数据投毒、prompt injection、训练数据泄露等风险类型，以及端到端风险评估。
- Google, *SAIF Risk Assessment*. <https://blog.google/innovation-and-ai/technology/safety-security/google-ai-saif-risk-assessment/>。用于说明 SAIF 可转化为问卷式风险清单，覆盖训练、调优、评估、模型与数据访问控制、对抗输入、防护编码框架和 agent 相关问题。

14 配图接口

15 结语

本主题的实务判断很清楚：AI 在安全测试里最适合做增强器，尤其适合报告整理、威胁建模初稿、测试用例扩展、脚本辅助和证据归纳。它也最容易在缺少上下文、缺少证据、缺少人工复核时变成风险源。

把 AI 工具放进可治理环境，核心在于让每一次使用都能回答六个问题：谁授权、用什么数据、做了什么、留下什么证据、谁复核、出了问题谁负责。能回答这些问题，AI 才能从演示能力变成组织能力。

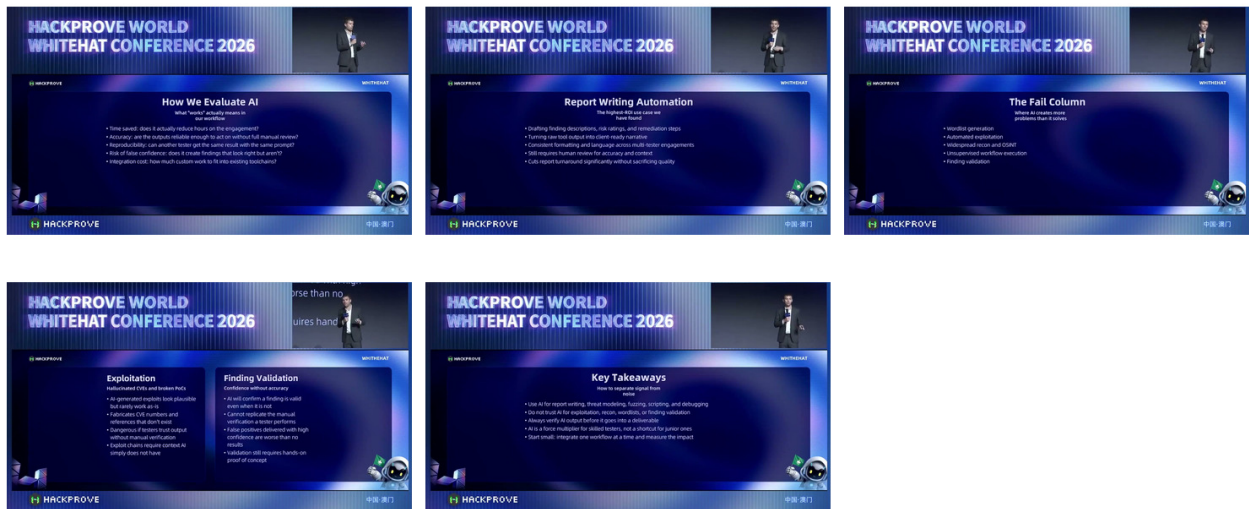


图 1: 主题 03 截图接触表: 多页候选画面覆盖 AI 安全运营的讲者、报告自动化、工具增强与流程治理, 可作为本节图像索引。²



图 2: 报告写作自动化的 ROI 页面: 该图说明 AI 能承担描述、风险评级、修复建议和格式一致性等重复劳动, 同时仍需人工审阅准确性与上下文。⁴



图 3: 工具增强与持续改进画面：讲者把 AI 工具放入运营闭环，突出权限、日志、责任分配和可解释报告这些治理约束。⁶